

# Governance Requirements for Coordinating Clinical AI Agents

Bruce Changlong Xu<sup>1</sup>, Ayush Chopra<sup>2,3</sup>, Alexander J. Ryu<sup>4</sup>

<sup>1</sup>Stanford University, Palo Alto, California, USA

<sup>2</sup>Massachusetts Institute of Technology, Cambridge, Massachusetts, USA

<sup>3</sup>Project Iceberg at MIT, Cambridge, Massachusetts, USA

<sup>4</sup>Mayo Clinic, Rochester, Minnesota, USA

Correspondence: Alexander J. Ryu, Ryu.Alexander@mayo.edu

## Abstract

Clinical AI agents may create harms through interactions across shared patients, workflows, data, and resources even when individual outputs appear acceptable. We introduce Clinical Infrastructure for Reliable Coordination (CIRC), a conceptual framework linking a non-exhaustive taxonomy of agent-local, interaction, and institutional risks to independent governance controls and observable evidence. CIRC is not a standard or validated architecture; it offers a starting vocabulary for evaluating coordination requirements before clinical deployment.

## 1 Introduction

Clinical artificial intelligence (AI) is shifting from decision support toward systems that choose and execute steps in clinical or administrative workflows.[1–3] In this Perspective, a *clinical agent* pursues a delegated objective by selecting workflow actions with less immediate human initiation than conventional decision support. Administrative, supervised clinical, and clinically consequential agents warrant different controls.

FHIR, SMART on FHIR, and CDS Hooks already support data exchange, authorization, and workflow-triggered decision support.[4–6] Profiles, implementation guides, workflow engines, and local extensions can support agentic workflows. The narrower question is which additional conventions are needed when software actors operate continuously across organizational and vendor boundaries.

Harms can arise from stale state, unmet prerequisites, incompatible actions, retry loops, resource congestion, or escalation without an accountable recipient. We call dependency-driven harms *interaction risks*. They do not necessarily require a new protocol: orchestration, EHR controls, policy engines, or human-led processes may provide the needed safeguards.

Evaluation should distinguish agent-local error from failures of shared state, dependencies, handoffs, resources, or institutional response. We introduce Clinical Infrastructure for Reliable Coordination (CIRC) as a conceptual governance framework for requirements analysis and protocol design, not a standard, implemented architecture, or certification scheme. CIRC contributes a non-exhaustive risk taxonomy, independent governance levers tailored to deployment context, and a mapping from risks and controls to observable evidence. Its trace-based example also identifies which multi-agent risks remain untested. The levers are neither minimal nor sufficient.

## 2 Existing infrastructure: capabilities and remaining gaps

Healthcare interoperability standards already provide substantial coordination infrastructure. FHIR Provenance and AuditEvent record actors, activities, policies, and outcomes; Task represents work state, ownership, inputs, outputs, composite tasks, and workflow links; and Subscription supports notifications. SMART Backend Services authorizes headless applications, while CDS Hooks invokes services at clinical workflow events.[4–8]

General-purpose agent protocols add further machinery. A2A defines discovery, signed capabilities, stateful tasks, cancellation, updates, authorization states, and extensions.[9, 10] MCP connects models to isolated tool and

resource servers through a host-controlled architecture.[11, 12] ACP-style protocols support task and message exchange.[13] The remaining question is which healthcare-specific semantics and conformance expectations should be shared.

Table 1 separates existing capabilities, extension or local implementation options, and governance contracts that lack consistent standardization. Many CIRC levers can be implemented today; CIRC links those choices to explicit risks and evidence requirements.

Table 1: Existing infrastructure and the narrower coordination questions raised by CIRC.

| Standard or approach               | Capabilities already provided                                                                                                                            | Extension or governance work for clinical-agent use                                                                                                                                                             |
|------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>FHIR resources</b>              | Structured clinical data; Task lifecycle, ownership, inputs, outputs, and composite work; Provenance and AuditEvent; event subscriptions.                | <b>Semantics and conformance:</b> profiles can encode agent versions, dependencies, and state, but common clinical-agent profiles, required fields, and cross-vendor behavior would need agreement.             |
| <b>SMART on FHIR</b>               | OAuth-based authorization for user-facing and headless clients; patient and encounter context; resource-level scopes and token introspection.            | <b>Authorization policy:</b> local policy can restrict actions, but patient-specific authority, degree of autonomy, approval conditions, and revocation across agents require explicit policy and enforcement.  |
| <b>CDS Hooks</b>                   | Synchronous invocation at named clinical workflow events; context and prefetch; cards, suggestions, and SMART app launch.                                | <b>Workflow:</b> useful for human-mediated checkpoints, but not a durable multi-agent dependency graph, transaction protocol, or population resource controller.                                                |
| <b>A2A and ACP-style protocols</b> | Agent discovery, capability advertisement, messages, stateful tasks, status updates, cancellation, authentication patterns, and extensions.              | <b>Clinical governance:</b> healthcare intent, patient and encounter binding, action authority, clinical prerequisites, accountable escalation, and safe-mode semantics require domain profiles or local rules. |
| <b>MCP</b>                         | Host-mediated access to tools, resources, and prompts; capability negotiation; isolation of server connections; host control of permissions and consent. | <b>Scope:</b> MCP can expose governed clinical tools, but it is not a peer-agent workflow or shared clinical dependency standard.                                                                               |
| <b>Workflow and policy engines</b> | Stateful orchestration, business rules, human tasks, access decisions, retries, timeouts, and compensation within a governed deployment.[14]             | <b>Implementation and portability:</b> these may implement CIRC levers locally; cross-vendor semantics, evidence exchange, and institutional trust remain deployment-specific unless profiled.                  |

The AI Risk Repository and NIST AI Risk Management Framework characterize broad AI risks and governance functions, while clinical-agent benchmarks evaluate individual agents in realistic environments.[15–18] Multi-agent deployment adds concurrent action on shared patients, resources, and workflows. Four gaps illustrate the distinction.

## Inconsistent agent observability and attribution

FHIR Provenance and AuditEvent can distinguish human and software actors, activities, policies, outcomes, and signatures. Consistent profiles and policies must still link each clinical action to a stable agent and model version, delegation context, authority, and scope.

## Unstandardized clinical intent and dependency semantics

FHIR Task, RequestGroup, CarePlan, workflow definitions, and A2A extensions can represent clinical dependencies. A shared profile must still specify the prerequisites, timing, state versions, resource needs, escalation, and reversal obligations declared for each class of autonomous action.

## Authorization without a shared model of clinical autonomy

SMART scopes and A2A mechanisms authenticate applications, limit data access, and support additional authorization, but their policies are implementation-specific. Deployments must define whether an agent may read, recommend, draft, place, or execute an action; for whom and where; and with what approval and escalation. CIRC makes these distinctions auditable rather than replacing access control.

## Locally implemented system-level resource coordination

Many locally reasonable agent decisions can collectively overwhelm imaging, infusion, discharge, or specialist capacity, a pattern called a “digital stampede.”[19] Standards can represent relevant facts and workflow engines can arbitrate resources centrally, but aggregate demand signals and population stress tests are not routinely portable across agent ecosystems.

The Ripple Effect Protocol motivates this pattern but does not validate CIRC or establish clinical transfer. CIRC does not require its sensitivity-sharing mechanism. Any aggregate signal would need separate evaluation for privacy, manipulation, fairness, workflow effects, and clinical safety.

## 3 A non-exhaustive taxonomy of clinical-agent risk

CIRC begins with risks rather than levels. The taxonomy is intentionally non-exhaustive: it is a starting point for requirements analysis, not a claim to enumerate every hazard or rank deployments on a maturity scale. We organize risks by the locus at which evidence and control are needed (Table 2). A single event can occupy more than one domain, and risk domains do not imply causal independence.

Table 2: A non-exhaustive taxonomy of clinical-agent risks.

| Risk domain                               | Illustrative risks                                                                                                                                                                                                                                        | Primary unit of evaluation                                                                 |
|-------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------|
| <b>Agent-local evidence and reasoning</b> | Wrong-patient or wrong-episode attribution; temporal misalignment; substitution of codes or orders for clinical evidence; incomplete evidence retrieval; rule misapplication; unsupported inference; false closure under missing or conflicting evidence. | One agent’s observable investigation, actions, report, and abstention behavior.            |
| <b>Interaction and workflow</b>           | Stale or inconsistent shared state; unmet prerequisites; incompatible or duplicated actions; failed handoffs; race conditions; incorrect dependency graphs; recursive retry or negotiation loops.                                                         | Concurrent trajectories around a shared patient, task, or care pathway.                    |
| <b>System and institutional</b>           | Resource congestion; correlated failure across patients; unavailable or misleading aggregate signals; escalation without an accountable responder; coordination-layer outage; cross-organizational trust failure; alert burden, inequity, and drift.      | Agent populations, shared resources, institutions, and human response processes over time. |

The first domain is already visible in emerging clinical-agent evaluations. CliniCARE-Bench, for example, evaluates retrospective clinical audits over 25 scenarios and 750 patient-specific cases in a governed, replayable EHR environment.[20] It separately scores final verdicts, patient-evidence grounding, policy use, process adherence, and calibrated abstention. Across 16 evaluated systems, reported four-way accuracy ranged from 65.3% to 76.1%, while accuracy that also excluded prohibited process shortcuts was 4.8 to 14.8 percentage points lower. Every evaluated system over-committed more often than it over-abstained. These findings do not validate CIRC and do not test multi-agent coordination. They demonstrate something narrower and useful: governance-relevant properties can be specified against observable traces, and a correct output can conceal a defective investigation.

Interaction and system risks require different evidence. A benchmark in which one agent reviews one record cannot measure cross-agent deadlock, conflicting modifications, population-level demand, or whether a clinician responds to an escalation. These risks require multi-agent replay, workflow stress tests, sociotechnical simulation, prospective shadow deployment, or post-deployment monitoring. CIRC uses the taxonomy to make those evidence boundaries explicit rather than treating single-agent accuracy as a proxy for system safety.

## 4 CIRC governance levers

CIRC maps risks to independent governance levers (Table 3). Each can be implemented through a protocol, central service, EHR workflow, or another architecture at deployment-specific strength; none is necessary, sufficient, or

unique to CIRC.

The seven levers follow from questions every deployment must answer: who acted; whether the action was permitted; what state and intent governed it; which dependencies applied; whether shared resources were affected; who assumed responsibility; and how failure was contained. This functional decomposition is neither empirical nor closed. Privacy, transport security, clinical validation, and model performance remain cross-cutting obligations, and evidence may revise the set.

Table 3: Lever-level crosswalk from existing infrastructure to residual coordination contracts.

| Governance lever                          | Existing substrate                                                            | Residual contract and gap type                                                                                      | Illustrative evidence                                                  |
|-------------------------------------------|-------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------|
| <b>Identity and attribution</b>           | OAuth and SMART identity; A2A authentication; FHIR Provenance and AuditEvent. | Stable agent and model version, delegation, and action linkage across systems (semantics and conformance).          | Signed identity, delegation chain, provenance, immutable audit event.  |
| <b>Scope and authorization</b>            | SMART scopes; OAuth tokens; policy engines; A2A authorization states.         | Patient-, action-, setting-, time-, and autonomy-specific authority with revocation (authorization and governance). | Scope declaration, policy decision, override and revocation record.    |
| <b>Structured intent and shared state</b> | FHIR Task and request resources; A2A tasks and messages; event middleware.    | Required action, patient context, state version, expiry, idempotency, and reversal (semantics and conformance).     | Typed intent, expected effect, state version, expiry, idempotency key. |
| <b>Dependency coordination</b>            | FHIR workflow resources; BPMN and workflow engines; task cancellation.        | Cross-vendor prerequisite, acknowledgement, cancellation, and compensation behavior (workflow and portability).     | Dependency graph, release checks, acknowledgement, cancellation log.   |
| <b>Resource and population awareness</b>  | Scheduling, queueing, and capacity systems within institutions.               | Governed demand, priority, concentration, and fairness signals where needed (implementation and governance).        | Timestamped capacity and demand measures, allocation decision.         |
| <b>Operational human oversight</b>        | EHR work queues; workflow human tasks; institutional escalation policy.       | Named ownership, acknowledgement, deadline, fallback, suspension, and closure (governance and human factors).       | Assignment, response, override, fallback, and closure timestamps.      |
| <b>Monitoring and failure containment</b> | Audit and observability platforms; rate limits; circuit breakers.             | Action-class safe modes, common-mode detection, recovery authority, and evidence (operations and governance).       | Health state, replay protection, safe-mode event, recovery log.        |

Profiles, extensions, workflow or policy engines, or local governance can implement these contracts when all participants can represent, enforce, and test them. CIRC contributes the risk-to-requirement and evidence crosswalk, not proof that a new transport is needed. Controls overlap: identity supports audit but not state freshness; oversight contains conflict only with ownership, timing, and fallback; and resource signals may reduce congestion while adding privacy, manipulation, and allocation risks.

| Risk locus                      | Governance task                                                                       | Candidate levers                                                 |
|---------------------------------|---------------------------------------------------------------------------------------|------------------------------------------------------------------|
| <b>Agent-local</b>              | Establish whether evidence, timing, policy, scope, and uncertainty support an action. | <b>Identity; scope; structured state; oversight</b>              |
| <b>Interaction and workflow</b> | Preserve shared state and dependencies as actions cross agents and systems.           | <b>Structured intent; dependency coordination; containment</b>   |
| <b>System and institutional</b> | Detect correlated demand and maintain accountability during escalation or outage.     | <b>Resource awareness; oversight; monitoring and containment</b> |

Figure 1: CIRC connects risk loci to governance tasks and candidate controls. Arrows are intentionally not one-to-one: controls overlap, and the appropriate implementation depends on the deployment.

Architectures can divide levers among central workflows, policy engines, EHR services, supervisory agents, and direct messages. Protocol fields matter most across organizational or vendor boundaries; CIRC neither assigns every control to a new protocol nor prefers decentralized communication.

## 4.1 Operational definitions and a coordination message

An *interaction risk* is a potential or realized failure attributable to interdependence among actors, actions, shared state, or resources. A *collision* occurs when actions target the same state or resource during overlapping validity windows and violate a declared compatibility rule. A *scope violation* occurs outside authorization valid for the actor, patient, task, setting, time, and delegated purpose. A *dependency violation* releases an action despite an absent, failed, expired, or version-incompatible prerequisite. *Failure containment* holds, quarantines, compensates, or reverses a fault before it crosses a predefined boundary.

Listing 1 gives a non-normative coordination message for rescheduling imaging. Its fields could map to a FHIR profile, A2A extension, or local workflow schema; patient and encounter references are placeholders.

Listing 1: Illustrative structured coordination message.

```
{
  "schema": "circ.intent.v0",
  "message_id": "urn:uuid:example-message",
  "idempotency_key": "schedule-change-example-1",
  "actor": {
    "agent_id": "agent:scheduling:example",
    "version": "3.2.1",
    "issuer": "Organization/institution-a"
  },
  "authority": {
    "action": "schedule.modify",
    "delegated_by": "PractitionerRole/care-team",
    "policy": "Policy/outpatient-scheduling-v4"
  },
  "subject": {
    "patient": "Patient/example",
    "encounter": "Encounter/example"
  },
  "state": {
    "version": "W/example-etag",
    "observed_at": "2030-01-15T14:30:00Z"
  },
  "intent": {
    "proposed_action": "reschedule imaging",
    "target": "Task/imaging-example",
    "reason": "capacity adjustment"
  },
  "dependencies": [
    {"task": "Task/oncology-clearance", "required_state": "completed"},
    {"task": "Task/observation-visit", "constraint": "must_remain_scheduled"}
  ],
  "valid_until": "2030-01-15T15:00:00Z",
  "reversal": {"action": "restore_prior_slot", "deadline_minutes": 30},
  "escalation": {
    "owner_role": "oncology attending",
    "respond_by": "2030-01-15T14:50:00Z",
    "on_timeout": "hold"
  },
  "signature": "detached-jws:example"
}
```

The message exposes enough context to authenticate the actor, evaluate authority, compare state, inspect prerequisites, deduplicate retries, enforce expiry, and route conflict. Message validity does not imply clinical validity; it makes decision context inspectable and enforceable.

## 4.2 One possible deployment architecture

Figure 2 shows one centralized realization. A coordination service or workflow engine checks identity and policy, binds actions to EHR state, records audit evidence, and routes named human escalation. External agents remain subject to local policy. Equivalent controls may be distributed, embedded in the EHR, or divided among existing services.

## 4.3 Implementation patterns and trade-offs

The same governance lever can be realized through different architectures (Table 4). The appropriate choice depends on institutional boundaries, workflow stability, latency, reversibility, and the consequences of coordinator failure.

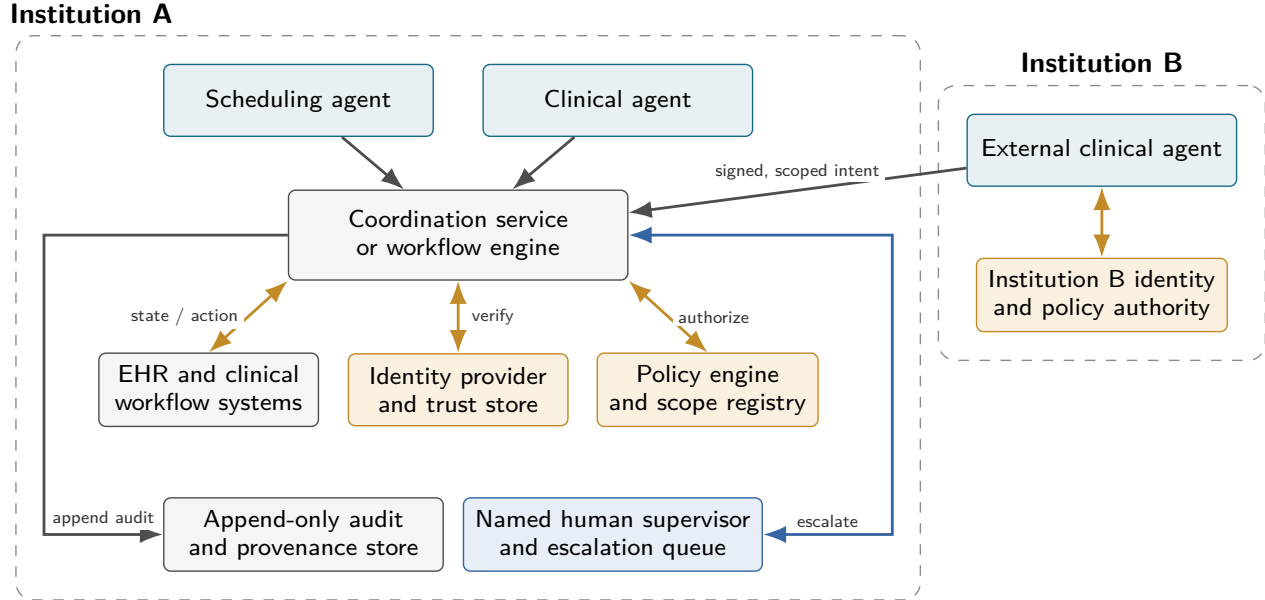


Figure 2: One possible implementation of CIRC governance levers. Identity, authorization, clinical state, audit, and human escalation remain institutionally governed even when an external agent uses a shared coordination message. The coordination service may be replaced by an EHR-native workflow or another architecture that provides equivalent controls and evidence.

Table 4: Alternative architectures for implementing CIRC governance levers.

| Pattern                                 | Principal strengths                                                                                | Limitations and role of shared conventions                                                                                                             |
|-----------------------------------------|----------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Central workflow orchestrator</b>    | One authority for sequencing, retries, compensation, and human tasks; clear operational ownership. | Can become a bottleneck or single failure domain; cross-vendor inputs still need stable identity, intent, state, and outcome semantics.                |
| <b>EHR-native workflow control</b>      | Close to orders, patient context, existing permissions, and clinician work queues.                 | May be vendor- or institution-specific and difficult to extend across external agents or non-EHR systems.                                              |
| <b>Policy engine and identity layer</b> | Centralized authorization, revocation, separation of duties, and consistent policy decisions.      | Does not by itself coordinate task state, clinical prerequisites, resource contention, or human response.                                              |
| <b>Supervisory agent</b>                | Can synthesize context and detect conflicts without requiring every peer to communicate directly.  | Introduces another model failure surface; requires bounded authority, independent monitoring, and deterministic enforcement for consequential actions. |
| <b>Distributed agent protocol</b>       | Supports cross-vendor discovery, delegation, and task exchange without one workflow owner.         | Increases consistency, trust, conflict-resolution, and outage-recovery demands; clinical profiles are needed above the transport.                      |
| <b>Human-led coordination</b>           | Uses existing professional accountability and adapts to unusual cases.                             | Limited by latency, workload, alert burden, and diffusion of responsibility; agent escalations still need named recipients and closure rules.          |

CIRC asks whether the chosen architecture provides each needed control and evidence trail. A FHIR implementation guide, A2A extension, or local orchestration policy may satisfy the contract; a new primitive is warranted only when existing representations or conformance cannot.

## 5 Failure model and degraded operation

A coordination layer is itself safety-critical infrastructure and can create common-mode failure. Systems-theoretic safety work likewise treats hazards as failures of interactions and control rather than only failures of individual components.[21] CIRC therefore assumes that agents, credentials, messages, state stores, dependency models, coordinators, and human response processes can each fail or be compromised. It does not assume that failures are independent or benign. The framework does not prescribe a universal identity issuer or consistency algorithm; it requires each deployment to declare its trust anchors, revocation mechanism, state guarantees, and degraded behavior. This follows a zero-trust posture in which access is evaluated for the requesting subject, resource, and context rather than inferred from network location.[22]

Table 5 states the principal failure surfaces. The controls are illustrative: their adequacy depends on clinical consequences, timing, reversibility, and organizational boundaries. Classical state-machine replication can improve availability and consistency, for example, but does not make an incorrect dependency model clinically correct.[23]

Table 5: Failure model for the clinical-agent coordination layer.

| Failure surface                         | Illustrative failures                                                                                                                      | Required containment behavior                                                                                                                                            |
|-----------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Identity and trust</b>               | Compromised agent; false scope declaration; credential theft; stale or unrevoked credential; untrusted external issuer.                    | Verify issuer, audience, version, delegation, and revocation at decision time; reject or quarantine the actor; preserve evidence for incident review.                    |
| <b>State and messaging</b>              | Stale patient state; loss, duplication, reordering, or replay; conflicting versions; delayed acknowledgement; network partition.           | Bind actions to state versions; use idempotency and replay protection; expose uncertainty; prevent irreversible execution on unresolved state.                           |
| <b>Dependency and workflow</b>          | Missing or incorrect prerequisite; cyclic dependency; deadlock or livelock; unbounded retry; partial cancellation or compensation.         | Validate graphs, bound retries, detect cycles, propagate cancellation, and freeze the affected pathway when consistency cannot be restored.                              |
| <b>Arbitration and resource signals</b> | Incorrect priority; manipulated or stale capacity; starvation; correlated demand; denial of service.                                       | Authenticate and timestamp aggregate signals, enforce rate and fairness policies, detect concentration, and transfer allocation to a designated fallback.                |
| <b>Coordination service</b>             | Outage, corrupted state, faulty arbitration, software update failure, or loss of quorum.                                                   | Use health checks and redundancy appropriate to risk; expose degraded status; restore from auditable checkpoints; avoid silent continuation under unknown control state. |
| <b>Human control path</b>               | Alert not delivered or acknowledged; wrong recipient; alert overload; automation bias; conflicting overrides; diffusion of responsibility. | Require named ownership, deadline and acknowledgement, fallback escalation, override authority, workload monitoring, and documented closure.                             |

Safe mode should be defined by action class rather than by one universal “fail closed” rule. Read-only retrieval or analysis may continue during partial outage only when data freshness and missing coordination context are visible to the user. Reversible administrative actions may be queued, deduplicated, or released after explicit confirmation. Actions that change treatment, orders, medication, disposition, or other consequential clinical state should generally be held when identity, scope, prerequisite, or shared-state checks are unavailable. Emergency exceptions require a predefined institutional pathway; the coordination layer should not invent one at runtime. In every case, the system should identify which guarantees remain active, return control to a named role, and record how normal operation was restored.

Cross-organizational identity requires federation rather than one global CIRC authority. Each institution can issue or recognize credentials under its own policy, while bilateral or network trust agreements define accepted issuers, assurance levels, claims, and revocation expectations. A valid identity establishes attribution, not clinical authority: authorization remains specific to the patient, action, setting, time, and delegated purpose.

## 6 Operational human oversight

“Human review” is not a control unless it changes who is responsible for what happens next. Health IT safety is sociotechnical: performance depends on people, tasks, technology, organizations, and the environment in which they interact.[24, 25] Automation can also redistribute attention and authority rather than simply reduce workload.[26] CIRC therefore treats oversight as an operational contract, not an endpoint label.

Every escalation should specify: (1) the accountable role and current assignee; (2) the triggering condition and supporting evidence; (3) the decision or action requested; (4) urgency and a response deadline; (5) whether the proposed action is blocked, queued, or continuing; (6) the fallback recipient and behavior after non-response; and (7) the event that closes the escalation. Assignment, delivery, acknowledgement, decision, override, and closure should be distinct auditable states.

Institutions must also define governance outside the immediate alert. A designated body should approve agent scopes and material changes; operational owners should be able to pause an agent; credential and policy administrators should revoke access; and a clinical authority should resolve conflicting recommendations. Separation of duties is important when one vendor supplies both the acting agent and the supervisory component. Escalation policies should suppress duplicates, group related concerns, set alert budgets, and monitor acknowledgement and override patterns so that adding a coordination layer does not simply add another source of alert fatigue.

Useful oversight measures include time to assignment, acknowledgement, and decision; fraction of escalations with no response by deadline; fallback activation; duplicate-alert rate; override and reversal rate; unresolved workload per accountable role; and the fraction of consequential actions executed without documented closure. These measures evaluate the response process rather than merely counting alerts.

## 7 Regulatory and institutional positioning

Regulatory status attaches to a software function, its intended use, users, claims, and deployment context—not to the labels “agent” or “CIRC” and not to a centralized or distributed topology. In the United States, FDA guidance distinguishes clinical decision support functions that satisfy the statutory non-device criteria from software functions that remain devices.[27] A multi-agent deployment may contain administrative functions, non-device decision support, and device software functions at the same time. Each function therefore requires its own assessment, including whether combining it with autonomous execution or other agents changes its intended use or risk.

For an AI-enabled device software function, an authorized predetermined change control plan can describe specified future modifications, the method for developing, validating, and implementing them, and the associated impact assessment.[28] CIRC records such as stable versions, delegation, policy decisions, dependency checks, reversals, and post-deployment events could support that lifecycle evidence. They do not establish safety or effectiveness, expand the authorized intended use, or make an out-of-plan modification permissible.

The European Union AI Act likewise bases obligations on intended purpose, statutory role, and classification. For systems classified as high-risk, Articles 9, 12, 14, 15, 17, and 72 address risk management, record keeping, human oversight, accuracy, robustness and cybersecurity, quality management, and post-market monitoring; Article 26 defines deployer duties.[29] CIRC levers overlap with several of these operational concerns, but implementing a lever is not itself a demonstration of conformity. Privacy, cybersecurity, medical-device, professional-practice, and health-system obligations also remain independently applicable.

Table 6: Regulatory obligations, CIRC operational evidence, and unresolved boundaries.

| Context                                     | Existing obligation or decision                                                                                             | CIRC operationalization                                                                              | Not resolved by CIRC                                                                                        |
|---------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------|
| <b>U.S. function classification</b>         | Intended use and statutory criteria determine whether a CDS function is a device.                                           | Inventory each function, user, action, autonomy, and responsible organization.                       | Legal status, intended-use claims, and applicable submission pathway.                                       |
| <b>FDA device lifecycle</b>                 | Premarket evidence and, when authorized, a PCCP govern specified AI-enabled device changes.                                 | Bind versions and modifications to validation, impact assessment, monitoring, and rollback evidence. | Safety or effectiveness, authorization of a change, and reporting thresholds.                               |
| <b>EU high-risk provider duties</b>         | Risk management, logs, oversight, robustness, quality management, and post-market monitoring (Arts. 9, 12, 14, 15, 17, 72). | Link identity, policy, dependency, escalation, safe-mode, and recovery records across agents.        | High-risk classification, conformity assessment, fundamental-rights analysis, and provider liability.       |
| <b>EU deployer and institutional duties</b> | Human oversight, log retention, monitoring, and incident action apply according to role and context (Art. 26).              | Name local owners, deadlines, fallback, pause authority, closure, and affected workflows.            | Professional responsibility, staffing adequacy, local law, and allocation of responsibility across vendors. |

The residual coordination gap is therefore operational rather than a claim that regulation is absent. High-level duties do not by themselves specify cross-agent state versions, dependency semantics, timeout and fallback behavior, or common evidence across vendor boundaries. CIRC offers a vocabulary for those interfaces while leaving classification, conformity, liability, and enforcement to the applicable authorities and institutions.

Before release, a deployment dossier should therefore map every consequential action to the function that proposes and executes it, its intended use and autonomy, the responsible legal and operational actors, applicable authorization, validation evidence, dependencies, affected populations, and fallback behavior. Changes to a model or agent version, permitted action, dependency, trust boundary, patient population, resource policy, or human fallback should trigger a recorded impact assessment proportional to the risk. This is an institutional change-control rule, not a claim that every change requires a new regulatory submission.

## 8 From risk taxonomy to evaluation

The taxonomy separates three questions that were conflated in the submitted simulations. First, can a risk be observed? Candidate measures include attribution completeness, stale-state reads, unresolved dependencies, duplicated or conflicting actions, retry amplification, queue concentration, safe-mode activation, and unowned or overdue escalations. Second, can a control detect or contain the risk without blocking valid work? Matched stress tests should report both fault containment and preservation of unaffected workflows. Third, does the control improve clinical or operational outcomes? That question requires prospective evaluation and cannot be inferred from a deterministic demonstration.

Trace-based benchmarks such as CliniCARE provide a concrete template for the first question. They log retrieval, computation, policy access, citations, and reports, allowing process defects to be separated from final-answer errors without inspecting private reasoning. Extending this approach to interaction risks would require linked traces from multiple agents acting on shared state, together with prespecified fault models, applicable denominators, baselines, repeated runs, uncertainty estimates, and failure cases. Population-level resource tests would additionally need realistic arrival processes, capacity constraints, and human response models.

Accordingly, this Perspective does not present the removed toy simulations as evidence of control effectiveness. Instead, it proposes a staged evaluation agenda: trace-based assessment of agent-local risks; matched multi-agent replay for interaction and workflow risks; system stress testing for shared resources and common-mode failure; prospective shadow deployment; and monitored clinical use where regulatory and institutional requirements permit.

## 9 Limitations and future directions

CIRC is a conceptual and non-exhaustive framework. It does not specify a complete technical implementation, establish the necessity or sufficiency of any lever, certify deployment readiness, or demonstrate clinical benefit. The taxonomy will require extension as clinical agents acquire new capabilities and as evidence emerges from real

workflows. Its categories also overlap: a stale-state error, for example, can reflect an agent-local retrieval failure, an interaction failure, and an institutional monitoring failure.

CliniCARE illustrates trace-observable agent-local risks, but it is a retrospective single-agent audit benchmark rather than a test of multi-agent coordination. Its findings cannot support claims about cross-vendor messaging, shared-resource control, human response, or prevented patient harm. Likewise, population-level clinical prediction is outside the scope of a coordination framework and must be developed and validated as a separate clinical model.

The threat model and oversight contract identify requirements but do not establish that any proposed implementation will satisfy them. Choices about trusted issuers, consistency, emergency exceptions, response deadlines, and safe-mode behavior remain institution- and action-specific. Governance questions also include liability, local configuration, alert burden, and equitable access. The regulatory discussion above is descriptive rather than legal guidance; applicability depends on the specific function, intended use, jurisdiction, and organizational role. Future work should compare protocol, orchestration, policy-engine, EHR-native, and human-led implementations against common risk-specific endpoints.

## 10 Conclusion

Multi-agent clinical safety cannot be inferred from individual-agent performance alone. The relevant risks span local investigations, interactions across shared workflows, and the institutions that authorize, monitor, and respond to autonomous action. CIRC offers a starting taxonomy for those risks and a set of independent governance levers that can be implemented through different technical architectures.

The framework’s value should be judged by whether it makes requirements and evidence more precise, not by treating its categories as a maturity ladder or its controls as established safety invariants. Existing trace-based benchmarks show how some agent-local risks can be measured. The next challenge is to build equally inspectable evaluations for shared state, dependencies, resource competition, degraded operation, and human response before autonomous clinical agents operate at scale.

## Acknowledgments

The authors received no specific funding for this work.

## Author contributions

B.C.X. contributed to conceptualization, methodology, investigation, visualization, drafting, and review and editing. A.C. contributed to conceptualization, methodology, and review and editing. A.J.R. contributed to conceptualization, supervision, and review and editing.

## Competing interests

The authors declare no competing interests.

## References

- [1] Michael Moritz, Eric Topol, and Pranav Rajpurkar. Coordinated ai agents for advancing healthcare. *Nature Biomedical Engineering*, 9:432–438, 2025. doi: 10.1038/s41551-025-01363-2.
- [2] Andrew A. Borkowski and Alon Ben-Ari. Multiagent ai systems in health care: Envisioning next-generation intelligence. *Federal Practitioner*, 42:188–194, 2025. doi: 10.12788/fp.0589.
- [3] R. Andrew Taylor. Ai agents, automaticity, and value alignment in health care. *NEJM AI*, 2(8), 2025. doi: 10.1056/AIp2401165.
- [4] HL7 International. Fast healthcare interoperability resources (fhir), release r4, 2019. URL <https://www.hl7.org/fhir/>.

- [5] HL7 International. Cds hooks specification, release 1.0, 2018. URL <https://cds-hooks.hl7.org>.
- [6] Joshua C. Mandel, David A. Kreda, Kenneth D. Mandl, Isaac S. Kohane, and Rachel B. Ramoni. Smart on fhir: a standards-based, interoperable apps platform for electronic health records. *Journal of the American Medical Informatics Association*, 23:899–908, 2016. doi: 10.1093/jamia/ocv189.
- [7] Health Level Seven International. HL7 version 2.5.1: Application protocol for electronic data exchange in healthcare environments, 2007. URL [https://www.hl7.org/implement/standards/product\\_brief.cfm?product\\_id=144](https://www.hl7.org/implement/standards/product_brief.cfm?product_id=144).
- [8] HL7 International. Smart app launch implementation guide, version 2.2.0, 2024. URL <https://hl7.org/fhir/smart-app-launch/>.
- [9] Rao Surapaneni, Mukul Jha, Matt Vakoc, and Todd Segal. Announcing the agent2agent protocol, 2025. URL <https://developers.googleblog.com/en/a2a-a-new-era-of-agent-interoperability/>.
- [10] A2A Protocol Working Group. Agent2agent protocol specification, version 1.0.0, 2026. URL <https://a2a-protocol.org/latest/specification/>.
- [11] Anthropic. Introducing the model context protocol, 2024. URL <https://www.anthropic.com/news/model-context-protocol>.
- [12] Model Context Protocol Contributors. Model context protocol architecture, 2025. URL <https://modelcontextprotocol.io/specification/2025-06-18/architecture>.
- [13] Samuel Besen and Anna Gutowska. What is agent communication protocol?, 2025. URL <https://www.ibm.com/think/topics/agent-communication-protocol>.
- [14] Object Management Group. Business process model and notation, version 2.0.2. Technical Report formal/2013-12-09, Object Management Group, 2014. URL <https://www.omg.org/spec/BPMN/2.0.2/>.
- [15] Peter Slattery et al. The ai risk repository: A meta-review, database, and taxonomy of risks from artificial intelligence. *arXiv preprint arXiv:2408.12622*, 2024. doi: 10.48550/arXiv.2408.12622.
- [16] National Institute of Standards and Technology. Artificial intelligence risk management framework (ai rmf 1.0). Technical Report NIST AI 100-1, NIST, 2023.
- [17] Yixing Jiang et al. Medagentbench: A virtual ehr environment to benchmark medical llm agents. *NEJM AI*, 2(9), 2025. doi: 10.1056/AIdbp2500144.
- [18] Dyke Ferber et al. Development and validation of an autonomous artificial intelligence agent for clinical decision-making in oncology. *Nature Cancer*, 6:1337–1349, 2025. doi: 10.1038/s43018-025-00991-6.
- [19] Ayush Chopra et al. Ripple effect protocol: Coordinating agent populations. *arXiv preprint arXiv:2510.16572*, 2025. doi: 10.48550/arXiv.2510.16572.
- [20] Veronica Chatrath, Bryan Zhu, George Pu, et al. Clinicare-bench: Clinical calibrated audit of medical reasoning in ehr. Scale AI Research, 2026. URL <https://labs.scale.com/papers/clinicare-bench>.
- [21] Nancy G. Leveson. A new accident model for engineering safer systems. *Safety Science*, 42(4):237–270, 2004. doi: 10.1016/S0925-7535(03)00047-X.
- [22] Scott Rose, Oliver Borchert, Stu Mitchell, and Sean Connelly. Zero trust architecture. Technical Report NIST SP 800-207, National Institute of Standards and Technology, 2020.
- [23] Fred B. Schneider. Implementing fault-tolerant services using the state machine approach: A tutorial. *ACM Computing Surveys*, 22(4):299–319, 1990. doi: 10.1145/98163.98167.
- [24] Dean F. Sittig and Hardeep Singh. A new sociotechnical model for studying health information technology in complex adaptive healthcare systems. *Quality and Safety in Health Care*, 19(Supplement 3):i68–i74, 2010. doi: 10.1136/qshc.2010.042085.

- [25] Pascale Carayon, Ayse Schoofs Hundt, Ben-Tzion Karsh, Ayse P. Gurses, Christian J. Alvarado, Michelle Smith, and Patricia Flatley Brennan. Work system design for patient safety: the seips model. *Quality and Safety in Health Care*, 15(Supplement 1):i50–i58, 2006. doi: 10.1136/qshc.2005.015842.
- [26] Raja Parasuraman, Thomas B. Sheridan, and Christopher D. Wickens. A model for types and levels of human interaction with automation. *IEEE Transactions on Systems, Man, and Cybernetics Part A*, 30(3):286–297, 2000. doi: 10.1109/3468.844354.
- [27] U.S. Food and Drug Administration. Clinical decision support software: Guidance for industry and food and drug administration staff. Technical report, FDA, January 2026. URL <https://www.fda.gov/media/109618/download>. Final guidance.
- [28] U.S. Food and Drug Administration. Marketing submission recommendations for a predetermined change control plan for artificial intelligence-enabled device software functions: Guidance for industry and food and drug administration staff. Technical report, FDA, August 2025. URL <https://www.fda.gov/media/166704/download>. Final guidance.
- [29] European Parliament and Council of the European Union. Regulation (eu) 2024/1689 laying down harmonised rules on artificial intelligence, 2024. URL <https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng>.